

Which of the following activities are signs of "Shadow IT" activities?

- Employee installing Teamviewer using local administrator account to remotely connect to office laptop, so they can work from home.
- Employee uninstalling Company installed antivirus so that they can use Windows Defender, helping the company save money
- Employee putting the computer to sleep mode, and then power back on, so as to disable the DLP, to speed up the computer so that work gets done faster.
- Employee installing a cracked version of Microsoft Visio and Adobe Acrobat Pro, and uninstalling them promptly after use.

Which of the following is/are countermeasure(s) to protect data in transit?

- SSL/TLS with valid certificates
- HTTPS

Explain how secrecy can be achieved.

- Cryptography and access control

Which of the following are example(s) of continuous monitoring and authentication technology?

- User Entity Behaviour Analytic
- Ensuring logs where effective detection use case can be created, are forwarded to a suitable repository for parsing and detection engineering
- Perform regular threat modelling and review defence in depth posture, so as to identify any detection gaps and address them

Which of the following defines an "assume breach" posture?

- Setup an threat hunting team to actively look around the Company network for any signs of compromise or anomalies

Explain what is essential for a company to pay attention to, when incident response service is outsourced?

- A good service level agreement (SLA) that meets the company's required operational response timing.
- Accredited vendors who continuously hone their skills, keep it up to date and relevant to the threat and technology landscape

What is MTPE?

- Mean Time to Privilege Escalation

What security metrics are commonly used to measure Blue Team effectiveness?

- Estimated Time to Detection
- Estimated Time to Recovery

What item(s) in security posture is/(are) related to the IR process?

- Detection and Response

Which of the following should be included in a post-incident activity report?

- Timeline of events
- Impact and Root Cause of the incident
- Potential gaps and recommendations for people, process and technology
- Areas of improvement

Explain what the "Water Holing" attack is.

- An attack strategy, in which the attacker guesses or observes which websites the group often uses and infects one or more of them with malware.

Why are IoT devices more prone to cyber attacks, compared to other devices like a server or a network router?

- Users often leave their IoT devices in their default security configuration due to ignorance, complacency or laziness.
- Manufacturer often prioritises efficiency and functionality over security, resulting in security settings not turned on by default.

Which of the following can safely remove the data stored within an SSD?

- Encrypt the disk with a long random key and forget the key, then format the disk.
- Perform an ATA-Secure wipe on the SSD, assuming the feature is supported

How can "broken authentication" be prevented?

- Delete all cookies and perform a proper account log out, before closing the browser
- When using a chrome browser, use it in "incognito" mode to ensure no credentials are saved, and perform proper log out before closing the browser.

Which of the following statement(s) about Windows Registry and Windows Group Policy in a Windows Active Directory setting is/are true?

- Group Policy can be used to implement changes in the Registry to harden a computer. Registry keys can be created to implement specific software logic changes as they act as configuration settings for the software
- Group Policy is a Windows server feature that allows administrators to making changes to the working environment of user accounts and their associated computer. A Registry stores the program and system settings for a computer.

Explain what pass-the-hash attack is?

- It is a hacking technique that allows an attacker to authenticate to a remote server or service by using the underlying NTLM or LanMan hash of a user's password, instead of requiring the associated plaintext password

Which of the following statement about the contents of security awareness training is/are correct?

- It should be constantly updated to include new attack techniques and relevant considerations
- It should be delivered to all employees

Which of the following statement about policy and procedure is/are correct?

- Policy must be enforced by a proper authority while procedure outlines what needs to be done
- Policy should not contain too much prescriptive technical information while procedure needs to provide enough details to facilitate execution

Why would an attacker want to perform lateral movement after gaining initial access to a victim's computer or network?

- To gain access to other sensitive data that may otherwise not be available to the attacker due to access control restriction
- As an attempt to identify other network routes that may be able to bypass existing network defences such as strict firewall rules

Why do hackers use tools that are often pre-installed on specific operating systems (also known as "live off the land") to conduct their hands-on-keyboard attack?

- Evade detection as such attack can be "mistakenly" interpreted as system administration activities
- Using a custom malware will increase the risk of attack attribution as the blue team could potentially reverse engineer the malware